Information Security: Overview

Information Security refers to the set of practices, processes, and technologies designed to protect information — and the systems that store, process, or transmit it — from unauthorized access, use, disclosure, disruption, modification, or destruction. In simple terms, it is about keeping data safe: making sure the right people can access it, wrong people cannot, and the data itself stays accurate and available when needed.

Information exists in many forms — digital files, printed documents, spoken conversations — and information security is concerned with protecting it in all these forms, not just data stored on computers. However, with most information today being digital, the term is often used interchangeably with **cyber security**, which focuses specifically on protecting digital systems, networks, and data from cyber threats.

Importance of Information Security

Information security has become critical for individuals, businesses, and governments for the following reasons:

1. **Protection of sensitive data:** Organizations store personal, financial, and business data that must be protected from theft or leakage. A single data breach can expose millions of users' personal details.
2. **Business continuity:** Security incidents like cyberattacks can halt operations, causing financial loss and reputational damage. Strong security ensures systems keep running smoothly.
3. **Legal and regulatory compliance:** Many industries (banking, healthcare, e-commerce) are legally required to protect user data. Failing to do so can lead to heavy penalties.
4. **Trust and reputation:** Customers and partners trust organizations that safeguard their data. A breach can permanently damage an organization's reputation.
5. **Prevention of financial loss:** Cyberattacks such as fraud, ransomware, and data theft can cause direct financial damage; good security reduces this risk.
6. **National security:** Governments rely on secure systems to protect critical infrastructure (power grids, defense systems, banking networks) from attacks by hostile actors.

Attributes of Information Security

Information security is built around a core set of attributes (often called security goals or principles) that together ensure information stays safe and usable. These are commonly grouped as the **CIA Triad** (Confidentiality, Integrity, Availability), extended with **Authentication, Non-Repudiation, and Access Control**.

1. **Confidentiality: Refers to protecting information from being accessed or disclosed to unauthorized individuals.** This is about privacy — only people who are supposed to see the data should be able to see it. For example, encrypting a file ensures that even if it is stolen, only someone with the correct key can read its contents.
2. **Integrity: Refers to ensuring that information remains accurate, complete, and unaltered except by authorized action.** This is about trustworthiness of data — the information a user receives should be exactly what was intended, with no unauthorized changes. For example, if a hacker modifies the amount in a bank transaction, integrity has been violated.
3. **Availability: Refers to ensuring that information and systems are accessible to authorized users whenever needed.** This is about uptime and reliability — data and services should not be blocked or delayed for legitimate users. For example, a Denial of Service (DoS) attack directly targets availability by making a website or service unreachable.
4. **Authentication: Refers to the process of verifying the identity of a user, device, or system before granting access.** This answers the question "are you really who you claim to be?" Common methods include passwords, OTPs, biometrics (fingerprint, face recognition), and security tokens.
5. **Non-Repudiation: Refers to the assurance that a person cannot later deny having performed an action, such as sending a message or making a transaction.** This is about accountability and proof — digital signatures and audit logs are used so that once an action is taken, the person responsible cannot falsely claim they didn't do it.
6. **Access Control: Refers to the mechanisms that restrict who can view or use resources in a system, based on their identity and permissions.** This is about limiting exposure — even authenticated users should only be able to access what they are authorized to, and nothing more. For example, a regular employee should not have

access to the company's financial database, while a finance manager should.

Together, these six attributes form the foundation on which all information security practices, tools, and policies are built.

Threats and Vulnerabilities

Understanding security requires distinguishing between two related but different concepts:

- **Threat: Refers to any potential danger or event that could exploit a weakness and cause harm to a system, network, or data.** A threat is the "what could go wrong" — it could be a hacker, a virus, a natural disaster, or even human error. Threats exist whether or not a system has a weakness to exploit.
- **Vulnerability: Refers to a weakness or flaw in a system, application, or network that can be exploited by a threat to cause damage.** A vulnerability is the "open door" — an outdated software version, a weak password policy, or unpatched code are all vulnerabilities. On their own, vulnerabilities are harmless, but they become dangerous when a threat exploits them.

In simple terms: a **threat** is the danger, a **vulnerability** is the weakness that lets the danger in, and a **risk** is the potential loss that results when a threat successfully exploits a vulnerability. For example, a computer without antivirus software (vulnerability) is at risk of infection because malware (threat) exists that can exploit it.

Security Attacks

A **security attack** is any deliberate attempt by an unauthorized party to compromise the confidentiality, integrity, or availability of information or a system. Security attacks are broadly classified into two categories:

1. **Passive Attacks: Refers to attacks where the attacker monitors or intercepts data without altering it.** The goal is usually to gather information secretly, such as eavesdropping on network traffic or monitoring communication patterns. Since the data isn't changed, passive attacks are hard to detect but can be prevented through encryption.

2. **Active Attacks: Refers to attacks where the attacker actively modifies, disrupts, or damages data or system operations.** These are more noticeable since they alter normal behavior — examples include modifying data in transit, injecting malicious code, or shutting down a service. Active attacks are harder to prevent entirely but easier to detect than passive ones.

The remaining topics in this unit — unauthorized access, impersonation, denial of service, and malicious software — are all specific, common types of security attacks.

Unauthorized Access

Unauthorized Access refers to a situation where an individual gains entry to a computer system, network, or data without proper permission. This directly violates the **confidentiality** and **access control** attributes of information security.

Unauthorized access can occur through several methods:

- Exploiting weak or stolen passwords.
- Taking advantage of unpatched software vulnerabilities.
- Bypassing security controls through technical loopholes.
- Physical access to systems that should otherwise be restricted.

Consequences include theft of sensitive data, unauthorized modification of records, and use of the compromised system as a launch point for further attacks. Prevention typically involves strong authentication (like multi-factor authentication), strict access control policies, and regular monitoring of system logs for suspicious login attempts.

Impersonation

Impersonation refers to an attack in which a malicious actor pretends to be a legitimate, trusted user, system, or organization in order to gain unauthorized access or trick a victim into taking a harmful action. This attack primarily targets the **authentication** attribute of information security.

Common forms of impersonation include:

- **Phishing:** Sending fake emails or messages pretending to be from a trusted source (like a bank) to trick users into revealing

credentials.
- **Spoofing:** Faking an IP address, email address, or website to appear as a legitimate source.
- **Social engineering:** Manipulating people into breaking normal security procedures by pretending to be someone with authority (e.g., a fake IT technician asking for a password).

Prevention measures include verifying identities through multiple factors, being cautious of unsolicited requests for sensitive information, and using digital certificates to confirm the authenticity of websites and communications.

Denial of Service (DoS)

Denial of Service (DoS) refers to an attack that aims to make a system, network, or service unavailable to its legitimate users by overwhelming it with excessive traffic or requests. This attack directly targets the **availability** attribute of information security.

- In a basic **DoS attack**, a single system floods the target with requests until it can no longer respond to genuine users.
- In a **Distributed Denial of Service (DDoS) attack**, multiple compromised systems (often called a *botnet*) simultaneously flood the target, making the attack much larger and harder to block, since traffic comes from many different sources at once.

Effects of a successful DoS/DDoS attack include website downtime, loss of business revenue, and damage to customer trust. **Mitigation** strategies include traffic filtering, rate limiting, using firewalls and intrusion detection systems, and deploying dedicated DDoS protection services.

Malicious Software (Malware)

Malicious Software, commonly called **Malware**, refers to any software intentionally designed to cause damage to a computer, server, network, or data, or to gain unauthorized access to a system. Malware can violate confidentiality, integrity, and availability all at once, depending on its purpose. The most common categories relevant to this unit are viruses, worms, and trojan horses.

Viruses

A **Computer Virus** refers to a malicious program that attaches itself to a legitimate file or program and spreads by inserting copies of itself into other programs when the infected file is executed. In simple terms, a virus needs a "host" — it cannot spread on its own; it requires a user to run or share the infected file.

Key characteristics:

- Requires human action (like opening a file or running a program) to activate and spread.
- Can corrupt or delete data, slow down system performance, or render programs unusable.
- Spreads through infected files, email attachments, USB drives, or downloads.

Worms

A **Computer Worm** refers to a self-replicating malicious program that spreads automatically across networks without needing to attach itself to another program or requiring human action. In simple terms, unlike a virus, a worm does not need a host file or a user to trigger it — it can spread entirely on its own once it finds a vulnerable system.

Key characteristics:

- Exploits network vulnerabilities to move from one system to another automatically.
- Can spread extremely fast, consuming large amounts of bandwidth and system resources.
- Often used to create backdoors or deliver additional malware to infected systems.

Trojan Horses

A **Trojan Horse** refers to malicious software that disguises itself as a legitimate or useful program to trick users into installing or running it. In simple terms, like the mythological Trojan Horse, it looks harmless (or even helpful) on the outside but carries a hidden malicious payload.

Key characteristics:

- Does not self-replicate like viruses or worms; it relies on deception to get installed.

- Often used to create backdoors, steal sensitive information, or give attackers remote control of the infected system.
- Commonly delivered through fake software downloads, malicious email attachments, or deceptive links.

Quick Comparison: Virus vs Worm vs Trojan Horse

Feature	Virus	Worm	Trojan Horse
Needs a host file	Yes	No	Yes (disguised as one)
Needs human action to spread	Yes	No	Yes (to be installed)
Self-replicating	Yes (within host)	Yes (across network)	No
Primary method	Attaches to files	Exploits network vulnerabilities	Deception/disguise

Authentication: Definitions

Authentication is the process by which a system verifies that a user is indeed who they claim to be, prior to granting access to a resource, service, or account. It requires the user to provide valid proof of identity, rather than a system accepting a claim of identity at face value.

Authentication occurs routinely in everyday computing, such as entering a password to access an email account, scanning a fingerprint to unlock a mobile device, or entering a PIN at an automated teller machine. In each instance, the underlying objective of the system is the same: to confirm, through verifiable proof, that the individual attempting access is the legitimate, authorized user.

Authentication is distinct from two related concepts with which it is frequently confused:

- **Identification** refers to the act of claiming an identity, such as entering a username. This is a statement of identity, not proof of it.
- **Authentication** refers to the verification of that claimed identity, typically through a password, biometric trait, or similar credential.

- **Authorization** occurs after successful authentication and determines the specific privileges and permissions granted to the verified user. For example, successful authentication into an institutional portal does not, by itself, grant the ability to modify academic records; such permissions are governed separately by authorization.

In summary, identification is the assertion of identity, authentication is the verification of that assertion, and authorization determines the extent of access subsequently granted.

Types of Authentication

Authentication mechanisms are generally classified into distinct categories, based on the nature of the evidence presented to establish identity.

1. **Knowledge-Based Authentication ("something the user knows"):** This category relies on confidential information known only to the legitimate user, such as a **password** or a **personal identification number (PIN)**. It is inexpensive and straightforward to implement; however, its principal limitation is that possession of this knowledge by an unauthorized party compromises the security of the account.
2. **Possession-Based Authentication ("something the user has"):** This category relies on a physical item held by the legitimate user, such as an **identity card, smart card, security token, or a mobile device receiving a one-time password (OTP)**. Access is contingent not merely on knowledge of a credential but on physical possession of the associated item.
3. **Inherence-Based Authentication ("something the user is"):** This category relies on unique physiological or behavioural characteristics of the individual, such as a **fingerprint, facial structure, iris pattern, or voice**. Because such traits are inherently difficult to replicate or transfer, this method is regarded as comparatively robust. This category is examined in greater detail in the section titled "Biometrics."
4. **Location-Based Authentication ("somewhere the user is"):** This category relies on the verified physical location of the user, typically determined through GPS data or network information. For instance, a financial application may flag or reject a login attempt originating from an unexpected geographic location as a potential security concern.

5. **Multi-Factor Authentication (MFA):** This refers to the combination of two or more of the above categories to strengthen the verification process, such that the compromise of a single factor does not, by itself, result in unauthorized access. For example, access to a banking application may require a password (knowledge-based) in conjunction with an OTP delivered to a registered device (possession-based). This approach is significantly more secure than reliance on a single factor and is accordingly employed by most systems handling sensitive information, including banking and governmental portals.

Password Authentication

Password Authentication is the most established and widely implemented method of identity verification, wherein a user defines a secret string of characters at the time of account creation and is subsequently required to reproduce it correctly at each login attempt. The system retains a stored representation of this password, which is compared against the credential submitted at the time of authentication.

Password authentication remains prevalent for the following reasons:

- It requires no specialized hardware, resulting in low implementation cost.
- It is a familiar mechanism requiring minimal user training.
- It offers flexibility, as credentials can be modified readily in the event of suspected compromise.

Nonetheless, password-based systems are widely regarded as one of the weaker components of information security, primarily because their effectiveness is contingent upon user behaviour. Users frequently select passwords that are easily memorable, which correspondingly renders them more susceptible to being guessed or deduced. This vulnerability is examined further in the following section.

Password Vulnerabilities & Attacks

A **vulnerability** in the context of passwords refers to a weakness in the manner in which passwords are selected, stored, or managed, which may subsequently be exploited by an attacker. Commonly observed weaknesses include:

- The selection of short or simplistic passwords.

- The reuse of identical passwords across multiple accounts.
- The inclusion of easily obtainable personal information, such as a date of birth.
- The recording or disclosure of passwords to other individuals.
- The prolonged use of a password without periodic modification.

Owing to these weaknesses, attackers employ specific techniques designed to determine or reconstruct passwords. The two most prevalent techniques are described below.

Brute Force Attack

A **Brute Force Attack** is an attack method in which an adversary systematically attempts every possible combination of characters until the correct password is identified. This method does not rely on inference or probability; it proceeds through all possible combinations in a methodical and exhaustive manner.

- The technique is executed through automated software capable of generating and testing a substantial number of password combinations within a short period.
- As password length and character complexity increase, the total number of possible combinations increases correspondingly, thereby increasing the time required to execute a successful attack. This underlies the emphasis placed on length and complexity in password design.
- The effectiveness of brute force attacks is commonly mitigated through mechanisms such as account lockout after a specified number of unsuccessful attempts, or the imposition of a delay between successive login attempts.

Dictionary Attack

A **Dictionary Attack** is an attack method in which an adversary attempts a predefined list of commonly used words, real words, and previously compromised passwords, rather than exhaustively testing all possible character combinations. This method is predicated on the observation that users frequently select passwords that are not random, but instead consist of recognizable words, names, or common patterns.

- The attacker employs a compiled list of frequently used passwords, such as common words, names, or previously leaked credentials,

and tests each against the target account.
- The effectiveness of this method arises from the widespread tendency of users to select predictable, easily guessable passwords rather than random character sequences.
- This method is generally more efficient than a brute force attack, as it does not expend resources testing improbable combinations, and instead focuses on credentials with a higher likelihood of success.

Distinction: A brute force attack tests all possible combinations without exception, whereas a dictionary attack tests only those combinations considered probable. Consequently, brute force attacks are slower but will eventually succeed given sufficient time, while dictionary attacks are faster but succeed only if the actual password corresponds to a common or predictable entry.

Password Policy & Discipline

A **Password Policy** refers to a formal set of rules established and enforced by an organization to ensure that user-selected passwords meet a defined standard of strength and are managed securely. The objective is to minimize the likelihood of passwords being guessed, stolen, or otherwise compromised, by reducing reliance on individual user judgment.

A comprehensive password policy typically includes the following provisions:

1. **Minimum length requirement:** Passwords are required to meet a specified minimum number of characters, commonly no fewer than eight, as longer passwords present a substantially larger set of possible combinations.
2. **Complexity requirements:** Passwords are required to include a combination of uppercase letters, lowercase letters, numerals, and special characters, thereby reducing the likelihood of a simple, predictable password.
3. **Periodic expiry:** Users are required to change their passwords at defined intervals, ensuring that a compromised password does not remain valid indefinitely, even if the compromise goes undetected.
4. **Password history enforcement:** Users are prevented from reusing recently used passwords when changing credentials, thereby preventing circumvention of the expiry requirement through alternating between a limited set of passwords.

5. **Account lockout mechanisms:** Accounts are automatically locked, or subjected to a time delay, following a specified number of unsuccessful login attempts, thereby limiting the effectiveness of brute force and dictionary attacks.
6. **Restrictions on sharing and reuse:** Users are discouraged from recording passwords in accessible locations, disclosing them to other individuals, or reusing identical passwords across multiple accounts or platforms.

Password discipline refers to the responsible practices that an individual user is expected to observe independently of organizational policy, in order to safeguard their own credentials. This includes refraining from disclosing passwords to others, avoiding reuse of a single password across multiple accounts, avoiding the use of easily discoverable personal information, and promptly changing a password upon any suspicion of compromise. The effectiveness of a password policy is contingent upon consistent adherence to sound password discipline by individual users, as even a rigorously defined policy provides limited protection if practical safeguards are not observed.

Single Sign-On (SSO) — Kerberos

Single Sign-On (SSO) refers to an authentication mechanism that permits a user to authenticate once and subsequently gain access to multiple independent applications or services without the requirement to authenticate separately with each. Rather than maintaining and entering distinct credentials for numerous systems, the user establishes their identity on a single occasion and is thereafter granted access across all integrated services for the duration of the session.

This approach offers considerable benefit in terms of usability, as it reduces the number of credentials a user must maintain and the frequency with which authentication is required, thereby also reducing the incidence of weak, forgotten, or reused passwords. **Kerberos** is among the most widely implemented protocols enabling this form of single sign-on, and is commonly deployed within institutional and enterprise network environments.

Operation of the Kerberos protocol:

1. Upon initial login, the user authenticates their identity, typically via a password, to a centrally trusted authority referred to as the **Key Distribution Center (KDC)**.

2. Upon successful verification, the KDC issues the user a time-limited credential known as a **ticket**, thereby obviating the need for the user to repeatedly submit their password.
3. When the user subsequently seeks access to another service on the same network, such as an email system, shared file storage, or a networked printer, the previously issued ticket is presented in lieu of a fresh set of login credentials.
4. As this ticket is recognized and trusted by all integrated services, and is configured to expire after a defined period, the user is afforded continuous access throughout the session without repeated authentication, while the limited validity period constrains the extent to which a compromised ticket could be misused.

Advantage: The Kerberos protocol avoids the repeated transmission of the user's password across the network for each service accessed, thereby reducing the risk of interception, while simultaneously improving operational efficiency, as a single successful authentication suffices for the duration of the session.

Biometrics

Biometrics refers to the use of unique physiological or behavioural characteristics of an individual to verify identity, as an alternative to knowledge-based credentials (such as passwords) or possession-based credentials (such as identity cards). As such characteristics are intrinsic to the individual, they present considerably greater difficulty for replication, theft, or transfer than conventional credentials, and cannot be forgotten in the manner of a password.

Types of Biometric Techniques

1. **Fingerprint Recognition:** This technique relies on the distinctive pattern of ridges and valleys present on an individual's fingertip. It is among the earliest and most extensively deployed biometric methods, commonly utilized in mobile devices and institutional attendance systems, owing to the compact size, low cost, and rapid processing capability of the associated scanning hardware.
2. **Facial Recognition:** This technique relies on the distinctive geometric features of an individual's face, including the relative positioning of the eyes, the structure of the nose, and the contour of the jawline, captured through an imaging device. This method is presently

employed for mobile device authentication and for identity verification at points of entry, such as airports.

3. **Iris and Retina Recognition:** This technique relies on the unique patterns present in the coloured portion of the eye (iris) or the arrangement of blood vessels at the rear of the eye (retina). This method offers a high degree of accuracy, as iris patterns exhibit no observed correspondence between individuals, including identical twins; however, it typically necessitates specialized and comparatively costly scanning apparatus.
4. **Voice Recognition:** This technique relies on distinctive characteristics of an individual's vocal patterns, including tone, pitch, and speech cadence, generally requiring the user to articulate a designated phrase into a microphone. This method is well suited to telephone-based systems, such as banking helplines, although its accuracy may be affected by ambient noise conditions.
5. **Signature Recognition:** This technique relies on the distinctive manner in which an individual produces their signature, encompassing not only its visual form but also behavioural attributes such as writing speed, pressure applied, and pauses during execution. This method is commonly employed in banking contexts for the verification of cheques and official documents.
6. **Hand Geometry Recognition:** This technique relies on the overall dimensions and structural configuration of an individual's hand, including finger length and palm width. Although this method offers a lower degree of granularity than fingerprint recognition, it provides rapid processing and is frequently employed for physical access control within institutional or organizational premises.

Accuracy of Biometric Systems: FRR, FAR, and CER

No biometric system achieves perfect accuracy under all conditions; systems may, on occasion, incorrectly reject a legitimate user or incorrectly accept an unauthorized individual. These forms of error are quantified through three principal metrics.

- **False Rejection Rate (FRR):** This metric refers to the rate at which a biometric system incorrectly denies access to a legitimate, authorized user, erroneously treating them as unrecognized. For instance, if a registered user presents their own fingerprint to a scanner and the system fails to recognize it, this constitutes a false

rejection. An elevated FRR results in legitimate users being repeatedly and unnecessarily denied access.

- **False Acceptance Rate (FAR):** This metric refers to the rate at which a biometric system incorrectly grants access to an unauthorized individual, erroneously treating them as the legitimate user. For instance, if the biometric trait of an unauthorized individual is mistakenly accepted as corresponding to a registered account holder, this constitutes a false acceptance. An elevated FAR represents a substantial security risk, as it permits unauthorized access.
- **Crossover Error Rate (CER):** This metric refers to the point at which the False Rejection Rate and the False Acceptance Rate become numerically equal, and is employed as a composite measure of overall biometric system accuracy. Biometric systems typically incorporate an adjustable sensitivity or threshold setting: increasing this threshold reduces false acceptances at the expense of increased false rejections, while decreasing it produces the converse effect. The Crossover Error Rate represents the precise threshold at which both error types occur with equal frequency, and **a lower Crossover Error Rate indicates a more accurate and reliable biometric system**. This metric is frequently employed as a standard basis for comparison among competing biometric technologies.

Summary: The False Rejection Rate pertains to the erroneous exclusion of legitimate users, the False Acceptance Rate pertains to the erroneous inclusion of unauthorized users, and the Crossover Error Rate provides a single, consolidated indicator of the overall balance and accuracy achieved by a given biometric system, with lower values denoting superior performance.